

THE IS AUDIT PROCESS

MS. F. NKOSI, CISA| CEH

Objectives of the course

To provide knowledge and skills required to perform an internal and external audit of part of a quality information system and report on the effective implementation and maintenance of the information system.

ASSESMENT GUIDELINES

Continuous assessment	**40%**
Final examination	**60%**

EXPECTATION

THE DIGITAL MOVE

- Technology advancement has caused most businesses to change their way of doing business, from manual processes to computerized process using Information systems audit.
- This has led to many organization establishing their own IT/IS audit functions.

Information Technology/ Systems Auditing

- An Information Technology (IT) audit is an audit/ evaluation/ review of an organization's IT systems, operations and related control processes.
- Information Systems Auditing is the process of collecting and evaluating evidence to determine whether a computer system safeguards assets, maintains data integrity, allows organizational goals to be achieved effectively, and users resources efficiently (Weber, 2000)

The objectives are:

1. Evaluate the reliability of data from IT systems which have an impact on financial statements
2. Evaluate effectiveness of IT controls to ensure systems are functioning as intended
3. Ascertain compliance with applicable laws, policies and standards.

Why are IT audits Important

With the widespread use of IT systems and the large amounts of data stored on such systems, it is important that IT systems and the data stored within are reliable and secure

- Ascertain whether IT systems are adequately protected
- Ascertain whether IT systems provide reliable information
- Evaluate the risk of data tampering / data loss
- Ascertain wether IT systems are managed to achieve their intended benefits

The Need for IT controls and audit

1. Need to safeguard Information system Assets - The growing reliance on computer systems and need to safeguard Information system Assets.

- It includes protection of hardware, software, facilities, people, data, technology, system documentation and supplies.
- Security and abuse from inside and outside hacking , virus and access.

2. Maintenance of Data Integrity - Data integrity includes the safeguarding of the information against unauthorized addition, deletion, modification or alteration.

Management and Organization of IT Audit Function

- IS audit management comprise of **audit planning**, **actual audit implementation**, **IS audit resource management**, effect of prevalent legislation on the audit function and application of IS audit standards and guidelines etc.
- While establishing an IT audit unit function, the organization should define the scope and the objectives of the IT Audit section.
- Then need to define how it should be managed collectively and at individual audit level.

Management and Organization of IT Audit Function

- At the strategic level organization of IS audition function entails:
  - Performing and managing audit tasks to fulfil audit objectives
  - Ensuring competence of the audit function to perform different types of IS audits
  - Ensuring audit independence
  - Value addition to the organization when it comes to IT operations and management which in turn support achievement of organization goals and objectives.

Management and Organization of IT Audit Function

- The IS audit role should be clearly defined by an Audit charter. It is not necessary that the IS audit should be a standalone department.
- It can very well be a part of the internal audit, financial audit or many times as an independent audit group.
- **The audit charter** is the main document from where the objectives, role and scope of IS audit derives.
- The overall responsibility for IS audit is that of management and it is delegated to the IS audit function via the charter.
- The Charter should be approved by the highest level of management in the organization and if possible by the audit committee or board.

Management and Organization of IT Audit Function

- It is also required by the ISACA auditing standards that the scope, authority, responsibility and accountability of the IS audit function should be well documented and approved either by an IS Audit charter or an entity engagement letter.
- An engagement letter **an engagement letter** is more targeted and often limited to a single audit engagement with clear objectives.
- An engagement letter defines audit scope, audit objectives of a particular audit

Management and Organization of IT Audit Function

- The most critical thing to remember is that whether it is an internal or external engagement, management of IS audit should ensure that its function is independent and most preferably they should be reporting to an audit committee or the highest level of senior management, which may be the board of directors.

Internal Controls?

- Internal controls are usually composed of policies, procedures, and practices.
- The COSO(Committee of Sponsoring Organizations) defines **internal controls** as the process implemented by the board of directors, Management and those under their direction to provide reasonable assurance that control objectives are achieved with regards to:
  - Effectiveness and efficiency of operations
  - Reliability of financial reporting
  - Compliance with applicable laws and regulations
- Internal Controls provide reasonable assurance that the organization's business objectives will be achieved while minimizing risk
- Internal control is the most important and fundamental concept that an auditor should understand.

Types of controls

Preventative controls – Deter problems before they arise

Segregation of duties, installing antivirus

Detective controls – Discover control problem as soon as they arise

i.e Firewall to detect

Corrective controls – Remedy problems discovered with detective controls

i.e data backups



What Controls(preventative, Detective and corrective) could be put in Place to reduce the Risk of Fire in a computer lab?

Answers

1. Install fire alarms
2. Install sprinklers
3. Fire drill practices
4. Install Smoke detection
5. Install fire extinguishers
6. No smoking in the building
7. Install escape route maps
8. No naked flame in the building
9. Backup Data



Answers

Install fire alarms – **Detective Control**

Use Fire proof materials: **Preventative control**

Install sprinklers – **Preventative control**

Fire drill practices – **Preventative and detective**

Install Smoke detection- **Detective Control**

Install fire extinguishers – **Preventative Control**

No smoking in the building –**Preventative control**

Install escape route maps- **Detective control**

No naked flame in the building – **Preventative control**

Backup – **Corrective control**

Information Technology Controls

- Information technology controls (or IT controls) are specific activities performed by persons or systems designed to ensure that business objectives are met.
- They are a subset of an enterprise's internal control.
- IT control objectives relate to the confidentiality, integrity, and availability of data and the overall management of the IT function of the business enterprise.

Purpose of IT controls

- Minimize the risk i.e fraud, waste, and abuse
- Provide assurance on the accuracy and integrity of financial data
- Enable an organization to focus on creating value for customers and stakeholders

Internal Controls Specific to Information Technology

- **General Controls**: ensures that overall computer environment is stable and well managed.
  - Commonly include controls over data center operations, system software acquisition and maintenance, logical security, and application system development and maintenance.
- **Application Controls:** they are designed to help ensure the completeness and accuracy of transaction processing, authorization, and validity.

EXAMPLES

Strong Password Policy –General Controls

Anomally detection system – Application

General IT controls

- General controls are overall controls that ensure the effective operation of programmed procedures. They apply to all application areas.
- General IT control categories include
  1. Organization and management controls (IT policies and standards).
  2. Controls over system implementation
  3. IT operational controls.
  4. Physical controls (access and environment).
  5. Logical access controls.
  6. Acquisition and program change controls.
  7. Business continuity and disaster recovery controls.

Application Controls

- The objectives of application controls, which may be manual or programmed, are to ensure the completeness and accuracy of the records and the validity of the entries made therein.
- Application controls can be categorized into:
  - Input controls
  - Processing controls
  - Output controls

Input controls

- The main aim of input controls is to reduce errors in the data entered in the system for processing.
- Input controls include checking data and ensuring that: - Input data are authorized by the appropriate official., Data represent valid record of actual transaction. - Correctly classified for the purpose of accounting Example : Sequence checks : Batch control

Processing controls

- There are diVided into mechanical and programmed controls.
- Programmed control are done during the system development to ensure that only data related to a particular transaction is processed and not otherwise.
- Example: Enter email address checks that email has “@” and “. “

Output controls

- Controls relating to input and processing itself with the final objective.
- Relates precisely to the original input.
- •Represents the outcome of a valid and tested program of instructions.

Control Self Assessment(CSA)

- ISACA defines control self-assessment (CSA) as an assessment of controls made by the staff of the unit or units involved.
- It is a management technique that assures stakeholders, customers and other parties that the internal control system of the organization is reliable.
- In simple terms, CSA involves a structured approach to documenting business **objectives**, risks and **controls** and having operational management and staff **assess** the adequacy of **controls**.
- The main idea behind control self assessment is to visit or revisit an function or process to ensure that the controls are either satisfactory, as per management's intentions and design and also if these may be improved.
- It may also be used as a tool to identify if any new internal controls are required.

Control Self Assessment

- It also involves documenting a process or function, risk identification and then evaluation of the internal controls that are in place as risk mitigation measures so that risk is mitigated to a level that is acceptable to the management.

Objective of CSA

All controls self assessment exercises may have different objectives but the following four are key elements of any CSA assignment.

- Understand a function or process thoroughly. Mostly, the members from process owners' teams are also part of the CSA team. So they know the process in detail.
- Identify the risks associated with the process or function.
- Determining the acceptable level of risks
- Evaluating the existing controls, forming opinion about that and also evaluate if new controls will be suitable based on a cost benefit analysis

Benefits of CSA

1. Early detection of risks
2. More effective and improved internal controls
3. Developing a sense of ownership of the controls in the employees processes
4. Increased employees awareness of organizational objectives and knowledge of risk and internal controls
5. Necessary assurance given to the top management about the adequacy of internal controls as required by the various regulatory agencies and laws

Difference Between CSA and Audit

- The main difference that makes control self assessment distinct from internal audit is that the direction, scope and details of the CSA are determined by the management of the operating department.
- Audit department, internal or external, is not in the driving seat in the CSA exercise. They may be engaged as facilitators or for guidance but they are never part of the remedial measures recommendations.

The IS audit Process



1. Understanding Audit Subject Areas
2. Risk assessment and general audit work plan
3. Detailed audit plan

1. Verifying and evaluating controls
2. Testing controls (Compliance tests and substantive testing)
3. Issue discovery and validation
4. Documenting results

1. Gathering report requirements and drafting the report
2. Communicating results and issuing the report
3. Follow up

Planning

- Planning can be both short term(audit plan for an audit activity) or Long term (annual work plan)
- Information gathering:
  - An understanding of the overall environment,
  - Business practices and functions relating to the audit
  - Types of information systems and technologies supporting the business
  - Listing of all regulatory requirements in which the business operates
- ISACA IS auditing standards require the auditor to address the audit objectives and to comply with professional auditing standards

Planning(2)

Activities that can be carried out during planning

- Reviewing background information such as industry publications and/or annual reports
- Reviewing prior audit reports
- Understanding the business and IT long-term plans
- Talking with managers to learn about the business issues
- Researching the specific regulations that apply
- Are any IT functions outsourced?
- Walking through the organization's facilities/processes

Fieldwork

- During this phase, the audit team will physically be on site at the audit client's location performing the audit.
- Thus, auditors will review supporting documentation, conduct interviews, evaluate and validate controls. In addition they will also carry out compliance and substantive tests.
- Compliance Testing: Auditors perform tests of controls to determine that the control policies, practices, and procedures established by management are functioning as planned. This is known as compliance testing.

Example

Company Policy: Employees should change their password every three months

Compliance Test: Check if employees change their password every 3 months

Field work(2)

- **Substantive testing** : Substantive tests verify whether information is correct.
- If weak internal controls exist or if important controls are not in place, extensive substantive testing will be required. On the other hand, if controls are found to be effective, the amount of substantive testing required is significantly lower.

- **Example**

- Determine the correctness of transactions and account balances

Reporting and follow-up

- During Reporting auditors will : Provide draft reports for comments and obtain corrective action plan then later distribute appropriate reports to required individuals/ management
- During Follow-up auditors will review the corrective action plans and results. They will review new process and documentation.



Exercise

Consider the following audit procedure by Company A's IS auditor:

1. Created an audit plan and schedule
2. Elaborated on plan's details
3. Preliminary review
4. On-site evaluation of the area
5. Conducted the company's risk analysis
6. Verified it with extensive substantive tests
7. Cross-checked by comprehensive compliance tests

What aspects from the audit process are missing?

Solution

1. Reporting
2. Follow-up

IT audit assurance standards and guidelines

Ethics, audit standards and guidelines

- **Ethics:** Ethics is a set of moral principles that govern the behavior of a group or individual.
- **Standards :** Standard defines mandatory requirements for IS auditing
- **Guidelines :** provides guidance in applying IS auditing standards

Code of Professional Ethics



ISACA Sets forth this code of professional ethics to guide the professionals and personal conduct of members of the association.

IT auditors shall:

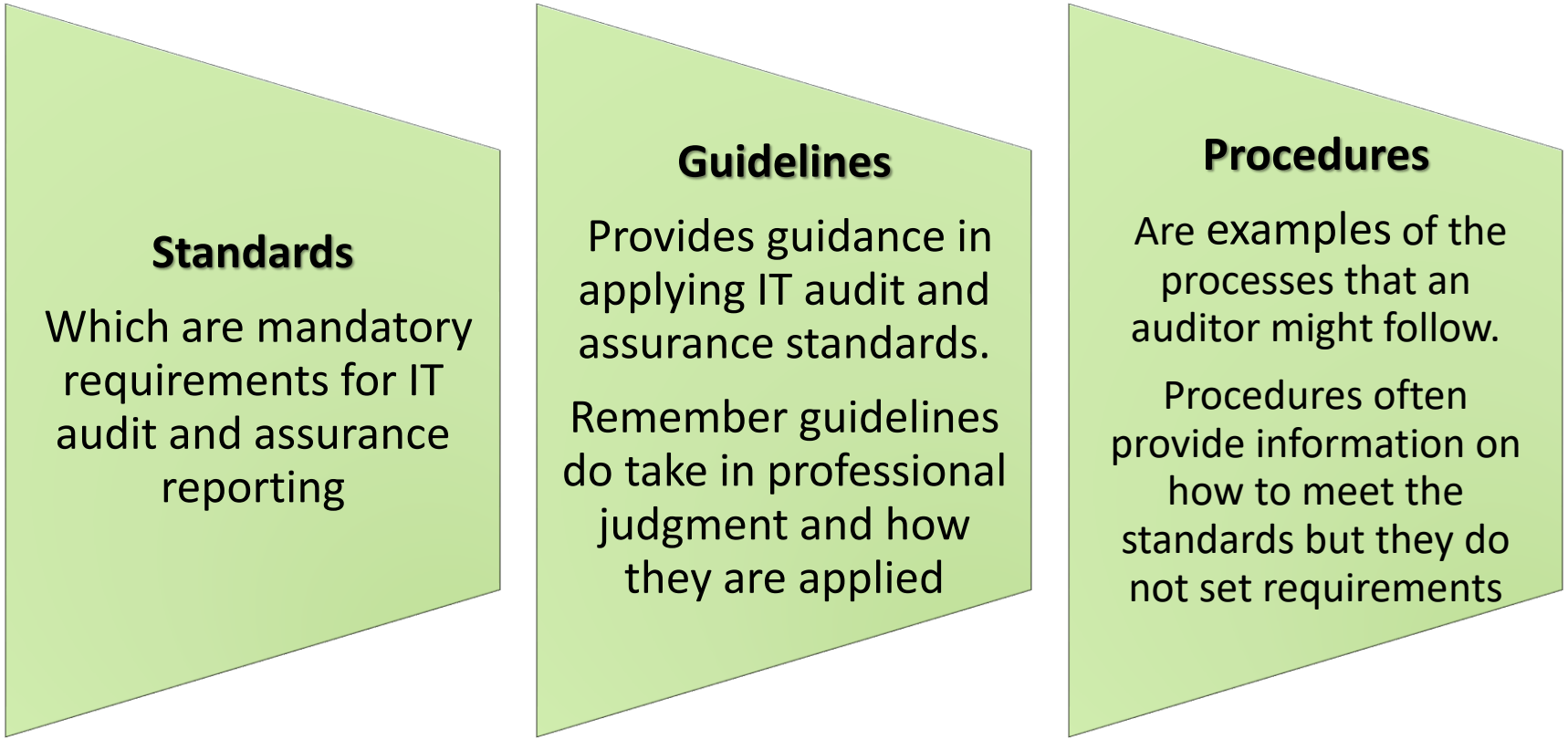
1. Support the implementation of, and encourage compliance with, appropriate standards and procedures for the effective governance and management of enterprise information systems and technology, including: audit, control, security and risk management.
2. Perform their duties with objectivity, due diligence and professional care, in accordance with professional standards.
3. Serve in the interest of stakeholders in a lawful manner, while maintaining high standards of conduct and character, and not discrediting their profession or the Association.
4. Maintain the privacy and confidentiality of information obtained in the course of their activities unless disclosure is required by legal authority. Such information shall not be used for personal benefit or released to inappropriate parties.

Code of professional ethics(2)

5. Maintain competency in their respective fields and agree to undertake only those activities they can reasonably expect to complete with the necessary skills, knowledge and competence.
6. Inform appropriate parties of the results of work performed including the disclosure of all significant facts known to them that, if not disclosed, may distort the reporting of the results.
7. Support the professional education of stakeholders in enhancing their understanding of the governance and management of enterprise information systems and technology, including: audit, control, security and risk management.

IT audit and assurance standards

The framework for IT audit and assurance standards (by ISACA) have the following levels:



ISACA Audit Standards

S1 Audit charter: This is the purpose, responsibility, authority and accountability of the IS audit function

S2 Independence: This includes professional independence in all matters related to the audit, and organizational independence in that the audit function should be independent of what is being audited

S3 Professional ethics and standards: The auditor should adhere to the ISACA code of professional ethics

S4 Professional competence: The IS auditor should maintain their skills and knowledge to professionally conduct the audit assignments

S5 Planning: The auditor should plan the manner in which the audit will be performed to cover all of the audit objectives as well as applicable laws.

ISACA Audit Standards (2)

S6 Performance of audit work: Auditors should be supervised to ensure the objectives are met. During the audit, adequate evidence is to be collected and well documented.

S7 Reporting: The report presented to client should state the scope, objectives, methodology, findings, conclusion and recommendations of the audit team. Evidence should be presented to support the findings.

S8 Follow-up activities: would be the reporting of recommendations to the organization for the purpose of bringing them into compliance

S9 irregularities and illegal acts

S10 IT Governance

S11 Use of risk assessment in Audit planning

ISACA Audit Guidelines

Audit evidence requirement effective May 1, 2008:

This guideline covers how the auditor should obtain sufficient and appropriate evidence and then draw reasonable conclusions based on the audit results.

Audit charter effective February 1, 2008: This guideline is designed to help the auditor prepare a charter, or contract, defining their responsibilities, authority, and accountability.

ISACA Procedures

- Procedures developed by the ISACA Standards Board provide examples of possible processes an IS auditor might follow in an audit engagement.
- The IS auditor should apply their own professional judgment to the specific Circumstances
- **It is not mandatory for the IS auditor to follow these procedures; however, following these procedures will provide assurance that the standards are being followed by the auditor.**
- P1 – IS Risk Assessment, effective 1 July 2002
- P2 – Digital Signatures, effective 1 July 2002
- P3 – Intrusion Detection, effective 1 August 2003
- P4 – Viruses and Other Malicious Code, effective 1 August 2003

Relationship Among Standards, Guidelines, and Tools and Techniques

- The ISACA standards are to be followed by the auditor.
- Guidelines provide assistance on how the auditor can implement the standards
- Tools and techniques provided is not an exhaustive guidance for the auditor but meant as examples of the steps that the auditor might follow